CYBERSECURITY AVANZATA · LEZIONE 2 · XSS, CSRF E CONTENT SECURITY POLICY

Il guestbook blindato

Un guestbook è la pagina più semplice del web: chiunque lascia un messaggio, tutti lo leggono. È anche il bersaglio perfetto per un XSS memorizzato. Scrivine uno in Java che resista.

Cosa consegni: un file **guestbook-cognome.zip** con **Guestbook.java** e un **README.pdf** di una pagina con le schermate, su Google Classroom. **Scadenza:** quella indicata su Novaula.

Che cosa devi fare

1. Con `com.sun.net.httpserver.HttpServer` (porta 8080) crea **GET /**, che mostra un modulo e tutti i messaggi, e **POST /scrivi**, che salva nome e messaggio in una `List` in memoria e torna a **/**.
2. Prova la versione **senza difese**: scrivi il messaggio `<img src=x onerror=alert(1)>` e fai la schermata del popup.
3. Aggiungi la funzione `escape` della lezione e usala su **ogni** dato mostrato. Rifai la prova: ora si vede il testo.
4. Aggiungi l'header `Content-Security-Policy: default-src 'self'` e controlla in DevTools che la pagina funzioni ancora.
5. Nel README spiega in 5-8 righe: quale tipo di XSS avevi, perché l'escaping lo ferma, che cosa aggiunge la CSP, e quale difesa CSRF metteresti su **/scrivi** se ci fosse un login.

Suggerimento

Per leggere il corpo della POST: `new String(ex.getRequestBody().readAllBytes(), UTF_8)`, poi dividi su `&` e `=` e usa `URLDecoder.decode`. Per tornare alla home rispondi con codice **303** e header `Location: /`.

> *"Non puoi fidarti del codice che non hai scritto tu, completamente."* · **Ken Thompson**, *discorso per il Premio Turing (1984). E nemmeno dei messaggi che scrivono gli altri.*

Come viene valutato

Criterio	Punti
Guestbook funzionante (GET e POST)	3
XSS dimostrato e poi corretto con l'escaping su tutti i campi	3
CSP presente e pagina ancora funzionante	1
Spiegazione corretta, compresa la difesa CSRF	2
Codice ordinato e commentato	1

Il server gira solo sul tuo computer (localhost). Non si provano attacchi su siti di altri.